Password Reset Broken Logic

1. Título

Restablecimiento de contraseña de otra cuenta mediante manipulación del parámetro `username`.

2. Descripción

La funcionalidad de restablecimiento de contraseña presenta un fallo de lógica que permite modificar la contraseña de una cuenta distinta de aquella para la que se emitió el token de recuperación.

Durante la prueba, se solicitó un enlace de restablecimiento para el usuario `wiener`. Mediante Burp Suite, se interceptó la petición `POST /forgot-password` y se modificó el parámetro `username=wiener` por `username=carlos`, conservando el token de recuperación original.

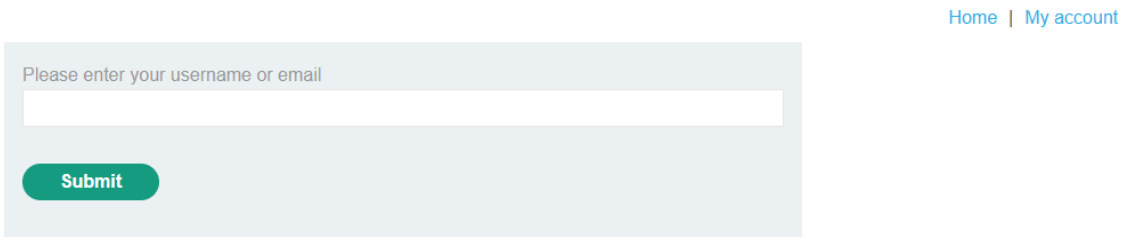
El servidor aceptó la solicitud modificada y permitió restablecer la contraseña de Carlos, lo que hizo posible iniciar sesión en su cuenta.

3. Evidencia

- página inicial del laboratorio.



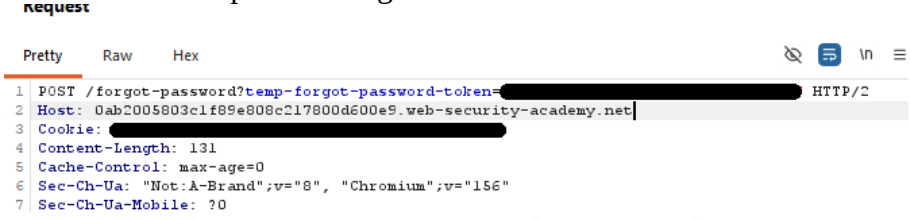
- formulario de recuperación de contraseña.



- enlace de recuperación recibido en el Email client.



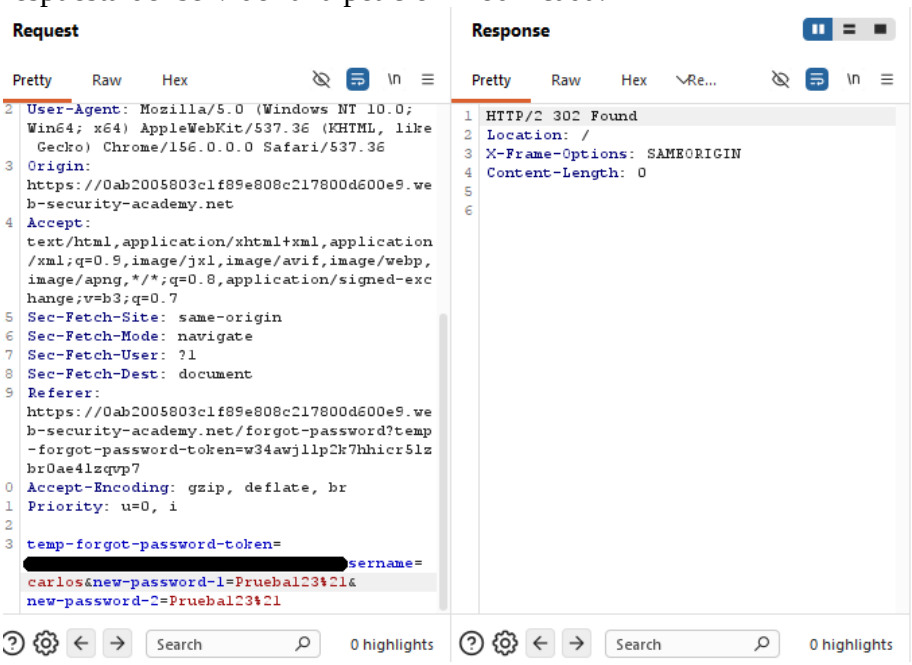
- encabezado de la petición original.



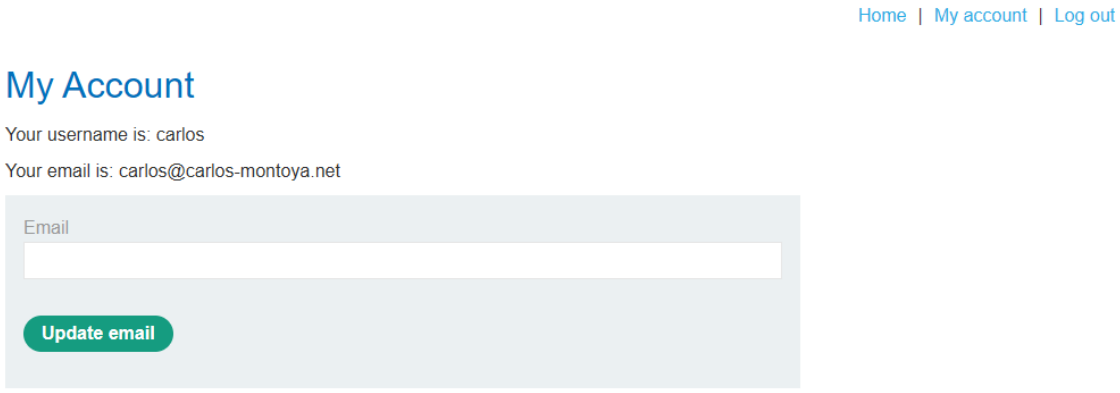
- cuerpo original con `username=wiener` y los campos de contraseña.



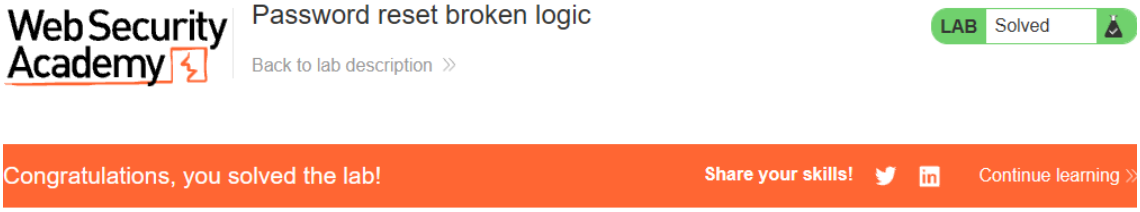
- respuesta del servidor a la petición modificada.



- acceso exitoso a la cuenta de Carlos.



- confirmación de PortSwigger de que el laboratorio fue resuelto.



4. Impacto (CIA)

- Confidencialidad: Alta. El atacante puede acceder a información privada de la cuenta afectada.
- Integridad: Alta. Puede modificar la contraseña de otro usuario y tomar el control de su cuenta.
- Disponibilidad: Posible impacto indirecto. El titular legítimo podría perder el acceso a su cuenta.

El impacto demostrado en el laboratorio es el cambio de contraseña y el acceso a la cuenta de Carlos.

5. Causa raíz

El servidor confía en el parámetro `username` proporcionado por el cliente para determinar qué cuenta debe modificarse. No valida correctamente que el token de restablecimiento esté asociado exclusivamente con esa cuenta.

La identidad del usuario objetivo debería determinarse y validarse del lado del servidor, sin depender de parámetros manipulables enviados por el cliente.

6. Remediación

- Vincular cada token de restablecimiento a una única cuenta del lado del servidor.
- Determinar la cuenta objetivo a partir del token validado, sin confiar en el parámetro `username`.
- Verificar que el token sea válido, no haya expirado y no se haya utilizado previamente.
- Invalidar el token después de un restablecimiento exitoso.
- Implementar limitación de intentos y registrar actividades sospechosas en el flujo de recuperación.
- Notificar al titular cuando se cambie su contraseña y considerar la revocación de sesiones activas.

7. CVSS aproximado

CVSS v3.1: 8.1 — Alto (estimación orientativa).

Vector propuesto: `AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N`

La puntuación supone que el atacante puede obtener un token para su propia cuenta y utilizarlo para modificar la contraseña de otra cuenta sin privilegios previos. Debe revisarse según las condiciones de explotación y el impacto del sistema evaluado.

8. Prioridad

Alta.

La vulnerabilidad puede permitir la toma de control de cuentas mediante el flujo de recuperación de contraseña. En un sistema real, se recomienda corregir la validación y asociación de tokens con prioridad.